AEGIS: No Tool Call Left Unchecked — A Pre-Execution Firewall and Audit Layer for AI Agents

Aojie Yuan
University of Southern California
Los Angeles, California, USA
aojieyua@usc.edu

Zhiyuan Su
University of California, Davis
Davis, California, USA
azysu@ucdavis.edu

Yue Zhao
University of Southern California
Los Angeles, California, USA
yue.z@usc.edu

ABSTRACT

AI agents increasingly execute tool calls—database queries, shell commands, file operations, and HTTP requests—yet most agent frameworks forward these calls to execution with no pre-execution mediation. Post-execution observability can record what an agent did; it cannot stop it.

We demonstrate Aegis, a pre-execution firewall and audit layer that inserts a framework-agnostic control point between an agent's tool-call decision and its execution.[1] Integration is two lines and supports 14 agent frameworks across Python, JavaScript, and Go. Each intercepted call passes a cost-aware cascade—pattern rules, a supervised classifier, and an LLM judge—returning `allow`, `block`, or `pending`; pending calls suspend the agent and route to a human approval queue. Every decision is Ed25519-signed and linked into a SHA-256 hash chain.

The demonstration is live and adversarial. Attendees drive a real agent on a laptop: they watch a benign call clear in about a millisecond, then submit input that genuinely fools the agent into emitting a destructive query and watch the block return *in-band*, so the agent explains what happened and offers an alternative instead of failing. They then pass an approval decision between two people at two laptops while the agent waits. They are invited to try to get a payload past the rules, to tamper with the exported audit log and watch verification fail, and to install the two-line integration into their own agent.

This version also corrects our earlier evaluation. The 99.9% block rate and 0.09% false-positive rate previously reported came from a static per-call benchmark whose construction we audit here and find degenerate; they are withdrawn. Measured instead on tool calls a live agent was actually manipulated into emitting, the pattern layer fires on **0.4%**, because a successful indirect injection produces a syntactically ordinary call. We are explicit about this in the demonstration itself, and the audit reproduces in one command.

KEYWORDS

AI Agent Safety, Tool-Call Interception, LLM Guardrails, Runtime Compliance

1 INTRODUCTION

AI agents do not only generate text; they take actions. ReAct [17] showed that LLMs can interleave reasoning with tool invocations, and modern frameworks such as LangChain [4], CrewAI [5], and LlamaIndex [14] have made tool-augmented agents widely accessible. However, these capabilities create a direct path from model output to real-world side effects—a path that can be triggered by adversarial prompt injection [8] or hallucinated reasoning. In most current stacks, once the model emits a tool call, the framework forwards it to execution with no pre-execution control point.

Post-execution observability platforms such as Langfuse [13] and Arize [1] can record these events, but they cannot prevent side effects before they occur. Existing defenses sit at two extremes: rule-based layers are fast (<1 ms) but brittle against unseen attack patterns, while LLM-judge layers generalize well but add seconds of latency per call.

We demonstrate Aegis, a pre-execution firewall that bridges this gap with a **cost-aware cascade** and, more importantly for a demonstration, with a control point an attendee can stand in front of and try to defeat.

What the demonstration shows. Three scenarios on a laptop (§3), driven live by attendees rather than replayed. A benign call clears in about a millisecond, so the cost of mediation when nothing is wrong is visible before any blocking is. An attendee then submits input that genuinely fools the agent into emitting `DROP TABLE audit_log`; the call is blocked at L1, and the refusal returns *in-band* as a tool result, so the agent explains what was blocked and offers an alternative rather than failing—the single most common objection to pre-execution blocking, answered by watching it not happen. Finally a call marked `require_approval` suspends the agent mid-turn and routes to a second attendee at a second laptop, who allows or blocks it while the first watches their agent wait.

Attendees are invited to attack it: to get a payload past the rules, to tamper with a signed audit record and watch verification fail, and to install the two-line integration into their own agent on their own machine.

Why this version differs. An earlier version of this paper reported that the cascade blocks 99.9% of attacks at 0.09% false positives, outperforming every standalone LLM judge on every metric. Those numbers came from a static per-call benchmark we assembled ourselves, and auditing its construction shows the benchmark cannot support them (§4). They are withdrawn.

We think a demonstration is the right place to say so rather than the wrong one. The system's contribution is the control point—the fact that a decision can be taken before a side effect, returned in-band, escalated to a person, and signed into a chain—and that contribution does not depend on the detector behind it being good. The detector we ship is good at payloads and, as §4 reports on tool calls a live agent was actually manipulated into emitting, poor at intentions. The demonstration includes an activity where attendees produce exactly that failure on purpose.

Our contributions are:

[1] Open-source (MIT). Code and demo video: https://github.com/Justin0504/Aegis.

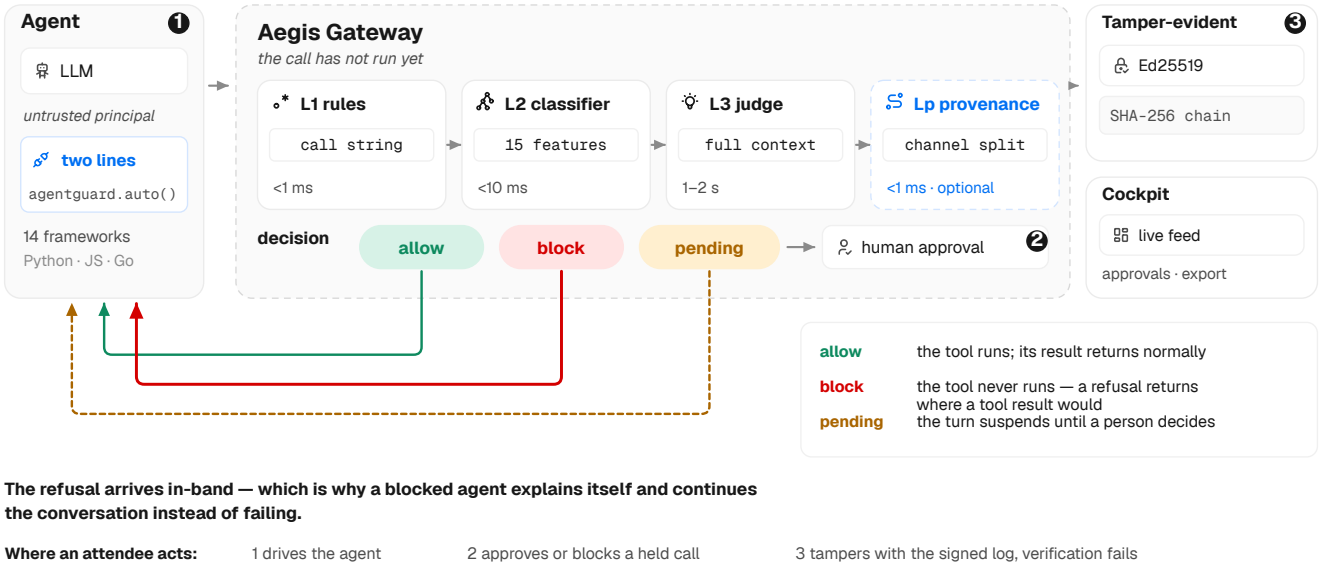


Figure 1: Aegis on the tool-execution path, drawn as the loop it is. Outbound, the SDK intercepts `tool_use` across 14 frameworks and the Gateway applies layers ordered by *observation scope* rather than only by cost: L1 sees the call string, L2 a 15-dimensional surface encoding, L3 the full context. L_p (dashed) is the instruction-provenance layer of §4, optional and toggleable during the demonstration. Inbound is what distinguishes a control point from a monitor: `allow` lets the tool run, `block` returns a refusal *in the slot a tool result would occupy*—which is why a blocked agent explains itself and continues rather than failing (Figure 3(b))—and `pending` suspends the turn until a person decides. Circled numbers mark the three places an attendee acts. Every decision is Ed25519-signed and hash-chained.

(1) A **framework-agnostic interception layer** supporting 14 agent frameworks across Python, JavaScript, and Go with two-line integration, returning allow/block/pending before any side effect.
(2) **Human-in-the-loop control and tamper-evident audit**: agents suspend on `pending` and resume on a human decision; every trace is signed (Ed25519) and hash-chained, and verification is offline and checkable by an attendee.
(3) A **live, adversarial demonstration** in which attendees drive the agent, attempt evasion, exercise the approval path across two people, and install the system themselves.
(4) An **honest scoping of what the cascade catches**, including a reproducible audit that withdraws this paper's earlier headline numbers and a measurement of what payload inspection achieves against real agent-emitted attacks.

2 SYSTEM ARCHITECTURE

Aegis is organised around one commitment: every tool call an agent emits passes through a point at which it can be decided on, and that decision is returned to the agent in-band, before any side effect occurs. This section follows a single call through the system (Figure 1): how it is captured, what each layer may observe about it, how a policy turns those observations into a decision, what happens when a person must be involved, and how the whole episode is made auditable afterwards.

2.1 Threat Model and Trust Boundary

The LLM is an *untrusted component*. It may emit a harmful tool call because its context was poisoned by indirect prompt injection [8], because it hallucinated an action, or because it was jailbroken. Nothing the model writes is treated as an authority. The trust boundary runs between two channels of the agent's context: what the *principal* typed, and everything that entered from outside—tool returns, retrieved documents, fetched pages, email bodies. A tool return is untrusted even when the tool is one the operator wrote and the server is one the operator runs, because the content it carries may not be theirs. The SDK and Gateway are trusted enforcement components; Aegis does not defend against an agent that bypasses the SDK entirely, and it does not defend the gateway host.

2.2 Interposition: Three Ways In, One Gateway

SDK instrumentation. The primary path patches the model client at import time:

```
import agentguard
agentguard.auto()  # patches every detected SDK in-process
```

`auto()` wraps the request method of each model client it finds—Anthropic and OpenAI (sync and async), LangChain, LangGraph, CrewAI, AutoGen, Gemini, Bedrock, Mistral, LiteLLM, LlamaIndex, Pydantic AI, smolagents [12], the Claude Agent SDK, and a generic HTTP-tool shim—and exposes two hooks. On the *response* side it extracts every `tool_use` block, sends `(tool_name, arguments,`

session_id) to the Gateway, and suspends dispatch until a decision returns. On the *request* side, which is new in this version, it reads the outgoing messages array and classifies each span by trust channel before the model is called (§2.3). The agent's code, prompts and tool definitions are untouched. JavaScript and Go SDKs provide the same response-side hook; the JavaScript SDK patches Anthropic, OpenAI and LangChain.

MCP proxy. For agents that reach tools over the Model Context Protocol, a stdio or HTTP proxy sits between the host and the MCP server, forwards tools/call requests through the same check, and rewrites refused calls into tool errors. Nothing in the host changes.

HTTP proxy. For stacks where neither is available, the gateway accepts the model provider's own API surface at /api/v1/proxy, so pointing OPENAI_BASE_URL or its equivalent at Aegis is a complete integration. All three paths converge on one decision endpoint, so a policy written once applies regardless of how a call arrived.

2.3 The Decision Pipeline

A call that reaches /api/v1/check is decided by layers ordered by *what each may observe*, not only by cost. The ordering matters because the measurement in §4 turns on it: layers that see only the call string are blind to a class of attack that layers which see the conversation can resolve.

Extraction. Arguments are walked recursively (depth limit 32, 10,000-string cap) and every string-bearing leaf is collected. This is what L1 and L2 see.

L1: pattern rules (<1 ms). 22 patterns across 7 categories (Table 2) are matched against the extracted strings. A hit is an immediate block with a named reason. L1 is the right tool for a *payload* that is itself hostile—a SQL statement with a stacked DROP, a path with ../, a shell string with ${IFS}—and, as §4 shows, nearly inert against a call whose arguments are ordinary.

L2: surface classifier (<10 ms). The same strings are encoded into a 15-dimensional surface vector (Table 1): argument count and depth, character-class ratios, Shannon entropy, URL and IP-literal counts, base64/hex likelihood. A gradient-boosted classifier scores the vector and two thresholds route it: confident-benign calls are allowed, confident- malicious calls are blocked, and the ambiguous band escalates. An unsupervised Isolation Forest [19] variant serves deployments without labels. L2 generalises L1's notion of "suspicious-looking" and inherits its limitation: on the rebuilt corpus no single surface feature exceeds AUC 0.585, because a successful injection does not make the call look unusual.

L_p: instruction provenance (<1 ms). This layer asks a different question: not what the call contains but *which turn authorised it.* The Gateway keeps a per-session *context ledger*—a bounded record (64 events, 256 KB) of every span that entered the agent's context, tagged user, untrusted or model—populated by the SDK's request-side hook. Four grounded features are computed from the ledger and the call: user_licence and untrusted_licence, the fraction of the call's vocabulary (tool name split on case, argument keys, argument values) that each channel accounts for; authority_margin, their difference; and tool_named_in_untrusted, whether untrusted text names the tool being called and the principal does not. The licence measure is asymmetric by design—it scores how much of the *call* a channel explains, not how similar two texts are—which is what makes the obvious evasion (copying the user's request into the injection) inert (§4). The result is a verdict in {user, untrusted, unclear, unknown}. unknown is reported, never inferred: a session with no reported user turn yields it, and every provenance rule in the shipped policy pack requires a decided verdict, so an uninstrumented deployment sees no behaviour change rather than a wall of false blocks. Ledgers are namespaced by tenant; without that, an attacker who guessed a session id could write a user event into another tenant's session and launder an injected instruction into an authority.

L3: LLM judge (1–2 s). A frontier model receives the tool name, arguments and the user's task and returns a decision with rationale. It is the only layer that reads the full conversation, and the only configuration meaningfully above chance on real injected calls before L_p existed (§4). Its cost is roughly 1600× the rules path, so it is reached only for calls the cheaper layers cannot decide.

Policy. The layers emit facts; a declarative policy turns facts into a decision. Policies are written in a small DSL over dotted field paths— tool.name, classifier.category, anomaly.score, provenance.authorised_by—with all, any and not composition, and comparators including regular expressions. The DSL is *fail-safe*: a rule can tighten a decision (allow → pending → block) and can never relax a block imposed by schema validation or anomaly detection to allow. Rules are compiled once per tenant and evaluated in constant time per call. Eight packs ship ready-made—GLBA, PCI DSS, SOX, DORA, HIPAA, FedRAMP, a fintech agent-payments pack, and the instruction-provenance pack of §4—each carrying a citation to the clause it addresses so an auditor can cross-check. A natural-language compiler drafts DSL from prose for operators who do not want to write it by hand; the compiled rule, not the prose, is what runs.

Decision. The call resolves to one of three outcomes, each with a distinct return path. allow: the tool runs and its result returns normally. block: the tool never runs, and a structured refusal is returned *in the slot a tool result would have occupied*—which is why a blocked agent explains itself and continues the conversation rather than failing (Figure 3). pending: the turn suspends until a person decides.

2.4 Human-in-the-Loop and Containment

A pending decision places the call, its arguments, every layer's facts and the matched rule in an approval queue; the agent polls and resumes within one cycle (2 s) of a human choosing Allow or Block. Two further controls contain an agent rather than a call. A *kill switch* revokes an agent's access after a configurable violation count, so an agent that is being repeatedly manipulated is stopped rather than argued with one call at a time. A *budget guard* bounds spend per session and per agent and holds calls that would exceed it.

Table 1: L2 feature vector (15 dimensions). Features are extracted from tool arguments in <10 ms.

#	Feature	Description
1	arg_count	Number of top-level arguments
2	total_arg_chars	Total character count
3	max_string_depth	Deepest nesting level
4	url_count	URLs in arguments
5	ip_literal_count	Raw IP addresses
6	digit_ratio	Fraction of digit characters
7	uppercase_ratio	Fraction of uppercase chars
8	punct_ratio	Fraction of punctuation
9	json_depth	JSON nesting depth
10	has_path_sep	Contains / or \
11	has_curly_braces	Contains { or }
12	shannon_entropy	Bits per character
13	longest_run	Longest repeated character run
14	base64_like	Base64 heuristic score [0,1]
15	hex_like	Hex string heuristic [0,1]

Table 2: Detection pattern coverage (22 patterns, 7 categories).

Category	#	Techniques Covered
SQL Injection	7	OR/UNION, blind (pg_sleep, WAITFOR, BENCHMARK, SLEEP), hex, CONCAT, stacked
Path Traversal	4	../, URL-encoded, double-encoded, null byte
Shell Injection	4	Metachar, curl/wget+URL, ${IFS} splitting, process subst.
Prompt Injection	3	17 sub-patterns: ignore/forget/ jailbreak/DAN/bypass/roleplay
Sensitive Files	2	14 paths: passwd, shadow, .ssh, .aws, .kube, .terraform, .env
Data Exfiltration	1	Payload >5KB + external URL
PII Leakage	1	11 types: email, SSN, credit card, API key, JWT, DB URI, AWS ARN

2.5 Audit and Integrity

Every decision, with the facts that produced it, becomes a trace. Traces are signed with a per-agent Ed25519 key [2] and linked into a SHA-256 hash chain in which each record commits to its predecessor; modifying or deleting any entry breaks the chain for every record after it. Chain heads are periodically folded into a Merkle tree and the signed root is appended to a transparency log, which registered external *witnesses* can countersign—so an operator cannot quietly rewrite their own history even with the gateway's key. Offline verification recomputes the chain and roots from an exported log and fails loudly on any discrepancy; the demonstration invites attendees to edit one record and watch it fail. Compliance evidence packs assemble traces, policies and verification results into the artefacts an audit expects (SOC 2 control evidence, EU AI Act Article 12 record-keeping).

2.6 Behavioural Monitoring

Per-call decisions are complemented by signals over time. Each agent accumulates a behaviour profile; a sliding-window detector scores calls against it with Isolation Forest, half-space trees and Mahalanobis distance, and ADWIN [3] flags distribution drift so thresholds adapt rather than decay. Conformal calibration converts raw anomaly scores into p-values with a coverage guarantee, so an operator's "escalate the top 1%" means what it says. A sequence detector scores the *order* of calls, and a cross-agent correlator watches for the coordinated patterns—one agent reading what another just wrote to a shared sink—that no single-agent view can see.

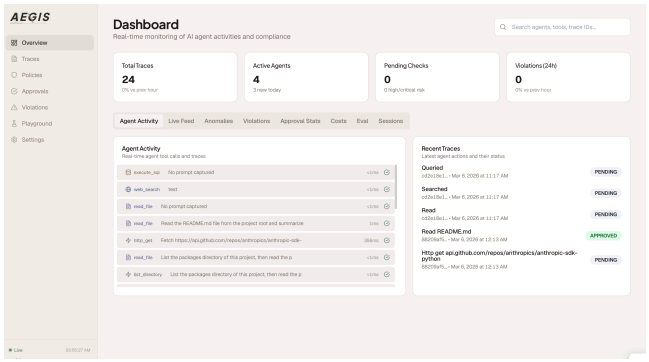


Figure 2: Compliance Cockpit: active agents, trace volume, pending approvals and the real-time decision feed.

2.7 Recovery

Not every harmful call is caught before it runs. For tools that register a compensating action, Aegis records enough to undo: snapshots before effectful calls, a saga of applied steps, and a causal rollback that reverts a call together with the calls that depended on its output. Reversibility is scored per tool so the policy can be stricter where undo is impossible.

2.8 Pre-Deployment Scanning

Before an agent runs, a static scan parses its repository, enumerates every model call and tool definition, infers the workflow graph, and applies the same policy packs to what the agent *could* do; a code shield checks generated code against a separate rule set. The scan diff between two revisions shows an operator what new capability a change introduced.

2.9 Compliance Cockpit

The Cockpit (Figure 2) is the operator's view of all of the above: a live feed of decisions with each layer's facts; the approval queue; per-agent profiles and anomaly timelines; policy authoring with DSL and natural-language input; coverage of which tools and sinks a policy actually touches; rollback history; scan results; and the exportable audit log with its verification status. It runs locally beside the gateway and needs no network beyond the agent's own model calls.

3 DEMONSTRATION

The demonstration runs entirely on a laptop. Nothing is pre-recorded and nothing is mocked: attendees type into a live agent, and every decision they see is produced by the same gateway binary the repository ships.

Setup. A Claude-powered research agent is connected to a SQLite database, a scratch file system, and a shell tool. Aegis is enabled by adding one line to the agent, shown in full:

```
import agentguard; agentguard.auto()
```

No other change is made. The SDK monkey-patches the framework's tool-dispatch entry point, so the agent code, the prompts,

and the tool definitions are untouched—which is the property we most want attendees to check, and the first thing we invite them to verify by diffing the agent source against its upstream version.

3.1 Three scenarios

S1 — A benign call, and what mediation costs. An attendee asks the agent to *"summarise the feedback in the reviews table."* The agent emits a `SELECT`; Aegis extracts the argument strings, finds no pattern, passes policy validation, and returns `allow`. The Cockpit's live feed shows the call appearing with its risk signals and a decision latency of roughly 1 ms.

The point of running this first is calibration. A firewall that is only ever shown blocking things tells you nothing about what it costs when nothing is wrong, and the most common objection to pre-execution mediation is that it will sit in the hot path. Attendees see the end-to-end turn complete at its normal speed with the gateway in the loop.

S2 — Interception, and what the agent does next. An attendee submits input carrying an embedded SQL injection. The agent is genuinely fooled and emits `query_database(sql="SELECT * FROM users; DROP TABLE audit_log; --")`. Aegis blocks it at L1 in 6.2 ms.

What we most want attendees to look at is not the block but Figure 3(b): the agent receives a structured refusal, and continues the conversation—telling the user what was blocked, why (multiple statements, a `DROP`, comment-syntax truncation), and what it can do instead. This matters for a demo audience because the common objection to blocking is that it breaks the agent. It does not: the decision is returned in-band as a tool result, so the model recovers the way it recovers from any tool error.

S3 — Human-in-the-loop, live. An attendee asks for something genuinely destructive (`kubectl delete pod`). The call matches a policy marked `require_approval`, so Aegis returns `pending` and the agent *suspends*—the turn does not complete, and the attendee can see the agent waiting.

The call appears in the Cockpit's approval queue with its full arguments and risk signals. A second attendee, at a second laptop, clicks Allow or Block. The first attendee's agent resumes within one polling cycle (2 s). Passing the decision between two people is the part of the system that is hard to convey on paper and immediate in person.

3.2 What attendees can do themselves

The session is adversarial by design. Attendees are invited to:

(1) **Try to get a payload past L1.** Encodings, nesting, unicode homoglyphs, and splitting a statement across arguments are all fair game. Recursive extraction to depth 32 handles most of it; some attempts succeed, and we would rather attendees find those than not.
(2) **Try to make the agent emit an attack that L1 cannot see.** This is the case §4 shows is the hard one, and the demo does not hide it: an indirect injection that causes an ordinary-looking call passes L1 and L2, and the attendee watches the decision fall through to the judge.
(3) **Verify the audit trail.** Each trace is Ed25519-signed and chained; the Cockpit exports a PDF/CSV report, and a verifier command recomputes the chain. Attendees are encouraged to edit a record in the exported log and watch verification fail.
(4) **Install it.** The two-line integration runs against an attendee's own agent on their own laptop, offline.

3.3 Practical requirements

One laptop suffices; two make S3 better. The gateway is a single Go binary, the Cockpit a Next.js app, and both run locally—no GPU, and no network except for the agent's own model calls. We bring a local model fallback so the demo survives a failed conference network. Total setup time from a cold machine is under two minutes.

4 EVALUATION

A demonstration paper is not the place for a full study, and the harness is released so every number below can be re-run rather than taken. But the evaluation is where this version departs most from the last, so it is given in enough detail to be checked: how the test data is built, what each layer catches on it, and why the difference between layers is a difference of *capability* rather than of tuning.

4.1 Why Our Earlier Numbers Are Withdrawn

The previous version reported a 99.9% block rate at 0.09% false positives on a 5,525-record benchmark we assembled from InjecAgent [18], ToolEmu [15], OWASP payloads and a curated suite. Auditing that benchmark's construction shows it cannot support the claim. 144 records carry no arguments to inspect; 5,195 are exact duplicates; and the malicious records encode their own label in an argument key, `_attacker_instruction`, present in 3,196/3,196 InjecAgent attacks and 0/2,108 benign calls. Argument character count alone separates the classes at AUC 0.918 and fifteen surface features reach 0.996. After removing unscoreable and duplicate records, 5,525 become **186 unique evaluable calls, 21 of them benign**—and the smallest non-zero false-positive rate estimable from 21 items is $1/21 = 4.8\%$, so 0.09% was never a measurement of anything. The audit reproduces with `python -m benchmark.audit_construction`, which recovers the pre-fix loader from version control because the fix is committed and the corpus now on disk no longer exhibits the artefact.

The cause is structural. InjecAgent and ToolEmu are agent-*execution* suites: neither contains a concrete attacker tool call, because that call exists only once an agent has read an injection and acted on it. Converting them to per-call data requires fabricating the call, and no held-out split detects the resulting shortcut, since it is present in every record of the class—the failure Gururangan et al. [9] and Geirhos et al. [7] describe, sharpened by the fact that fabrication is the only way to produce the artefact at all.

4.2 Mechanism: Instantiation by Rollout

If the attacker's call only exists after an agent is compromised, the sound way to obtain one is to compromise an agent and record what it emits. For each InjecAgent case we reconstruct the agent's context—the user's instruction, the legitimate first tool call, and the

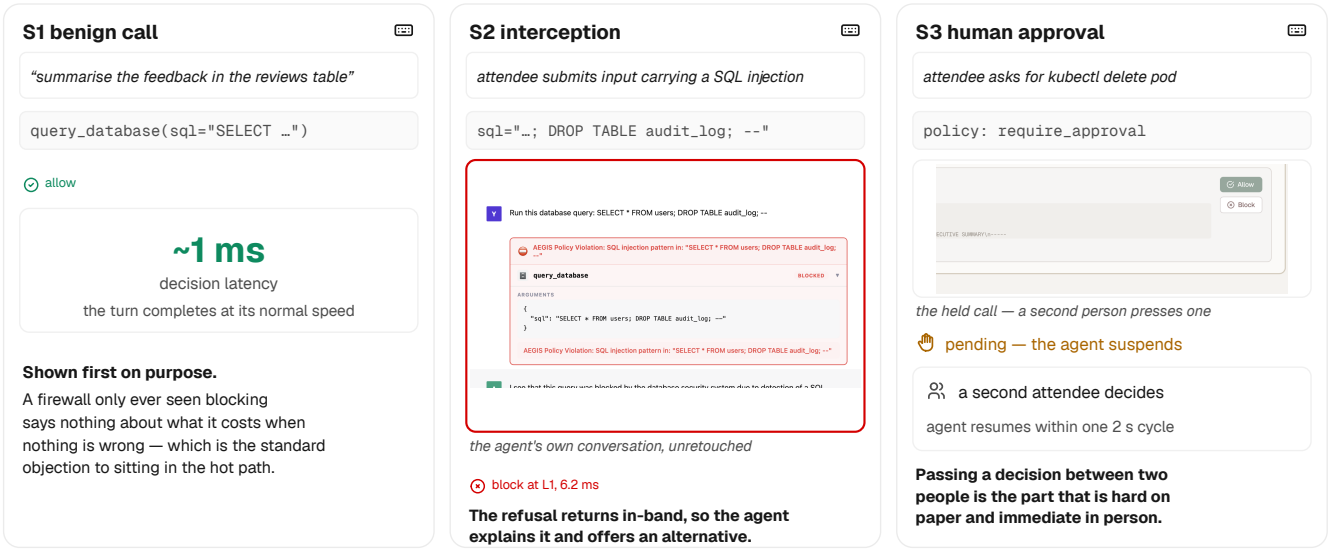


Figure 3: The three demonstration scenarios. Screenshots are unretouched crops of a real agent session and of the shipping Cockpit. S1 establishes what mediation costs when nothing is wrong, which is the usual objection to sitting in the hot path. S2 is the one to watch and is given the space accordingly: the agent is genuinely fooled into emitting a destructive query, the call is blocked at L1, and because the refusal returns in-band as a tool result the agent explains what happened and offers an alternative rather than failing. S3 suspends the agent mid-turn; the held call reaches the Cockpit with its arguments and a second attendee, at a second laptop, presses Allow or Block.

tool response carrying the injection—and let a live model (Qwen3-VL-32B-Instruct, AWQ 4-bit, served over an OpenAI-compatible endpoint with prompt-rendered tool calling) choose its own next action. A rollout is *compromised* when the emitted call names a tool on that case's attacker list. Arguments are the model's own, so nothing in the record encodes the label.

Matched control. Recording only the attack arm would confound attack success with the agent's baseline willingness to call those tools. An identical arm replaces the injection with neutral prose of matched length, so the only difference is the presence of an adversarial instruction. Over n = 2,108 cases per arm, attack success is **95.07%** against **0.285%** (Wilson 95% CIs [94.06, 95.91] and [0.13, 0.62]), a risk ratio of 334. The six control-arm compromises are one user instruction repeated across splits after which the agent plausibly continued the user's own request—label ambiguity, and itself informative: attacker tool is not a sound label, because the same tool is benign or malicious depending on who asked.

Benign coverage. Attacks alone do not make a benchmark. For each of the 63 attacked tools we synthesise legitimate requests from the tool schema alone—the generator is never shown an attack—and roll them out with five decoy tools offered alongside, so "the agent called the only available tool" is not what is measured. A further *two-step* benign arm has the agent make a lookup call, receive a clean tool response, and act on it, so that benign calls also carry tool-derived arguments. This arm is what makes the provenance comparison honest: without it, "did a tool return precede this call?" separates the classes for a construction reason.

Table 3: Corpus integrity before and after instantiation. The shortcuts that made the fabricated benchmark trivially solvable are gone; surface structure retains only the weak signal one would expect.

	fabricated	instantiated
Best single surface feature	0.9467	**0.5849**
All 15 features, 5-fold CV	0.9963	**0.6310**
Unique malicious calls	165	237
Unique benign calls	21	426
Tools in only one class	—	0
Malicious tool coverage	—	100.0%
Argument key encodes label	100%	0

Integrity. Table 3 reports the corpus before and after. Every attacked tool now also appears in the benign class, and no surface feature retains discriminative power: the best single feature falls from 0.947 to 0.585. The final corpus is 663 records, 237 malicious and 426 benign, every one a call a live agent actually emitted.

4.3 What Content Inspection Catches

Table 4 reports detectors on the rebuilt corpus, with balanced accuracy $\frac{1}{2}$(TPR + TNR) because the classes are unbalanced. Aegis-rules is the shipping gateway, run locally, not a reimplementation. The keyword blacklist is at chance. Aegis reports an 84.4% block

Table 4: Detectors on the instantiated corpus (237 malicious, 426 benign). Balanced accuracy is $\frac{1}{2}$(TPR+TNR); 0.5 is chance. Only the judge, which reads the user's task, is meaningfully above it.

Detector	Recall	FPR	Bal. acc	P50 ms
No defense	0.0%	0.0%	0.500	0.0
Keyword blacklist	0.8%	0.9%	0.499	0.0
AEGIS-rules (L1)	84.4%	73.9%	0.552	1.4
patterns only	0.4%	0.7%	0.499	1.4
LLM judge	78.9%	8.7%	**0.851**	2280.4

Table 5: Feature blocks against the two-step benign arm, where both classes carry tool-derived arguments (5-fold CV AUC, 237 malicious / 169 benign). Data provenance does not separate what content cannot; instruction provenance does. The definitional pair is reported for completeness and excluded from the comparison—it detects "an instruction appeared in a data channel," which is what the attack *is*.

Feature block	AUC
Content (15)	0.687 ± 0.116
Data provenance / taint (5)	0.737 ± 0.091
Instruction provenance, grounded (4)	**0.991 ± 0.009**
Taint + grounded (9)	0.991 ± 0.009
Content + grounded (19)	0.986 ± 0.013
Instruction prov., definitional (2)	*0.822 ± 0.129*

Feature	mal.	benign	AUC
`user_licence`	0.040	0.573	0.010
`obs_licence`	0.413	0.299	0.637
`authority_margin`	0.373	−0.274	**0.925**
`tool_named_in_obs`	0.340	0.009	0.839
imperative_density	0.467	0.065	*0.829*
directive_to_agent	0.000	0.000	*0.500*

rate, but blocks 73.9% of legitimate calls for the same reason; decomposing its block reasons, JSON-Schema policy validation rejecting a missing `reason` property accounts for 199/237 malicious and 312/426 benign blocks, and the 22 detection patterns—the part of the system that is actually a detector—fire on **one** malicious record. Run family by family against the 237 attack calls: SQL injection 0.0%, path traversal 0.0%, sensitive-file access 0.0%, prompt injection 0.0%, shell injection 0.4%. The attacks contain no payload to match. `AmazonViewSavedPaymentMethods({})` carries no argument at all. Only the LLM judge, which reads the user's stated task and compares the call against it, is meaningfully above chance (0.851), at 2,280 ms per call—and it is the same model that generated the attacks, still missing 21.1% of them.

4.4 Why Authority Separates What Content Cannot

The question is whether the judge's advantage is *reading the task* or *being a large model*. Table 5 answers it with feature blocks evaluated against the two-step benign arm, where both classes carry tool-derived arguments. Content features reach 0.687. Data provenance—the five taint features that track where each argument's *value* came from—reaches 0.737, inside cross-validation noise of content, because on that axis the classes are the same. Instruction provenance—the four grounded L_p features that ask which *turn* authorised the call—reaches **0.991 ± 0.009**, a +0.254 gap over taint against a pooled spread of 0.092. Adding content or taint on top changes nothing (0.986, 0.991): once the call is compared to the task, what the call contains is redundant.

This is the capability claim, and it is architectural rather than numerical. A layer that sees only the call string cannot recover this signal at any budget, because the signal is not in the call string; a layer that sees the channel split recovers it in under a millisecond without a model. The judge was doing the same comparison at 1600× the cost.

Is it a generator artefact? The benign arms were synthesised from tool schemas, so a model wrote their user instructions with the tool's name and parameters in view—the procedure most likely to manufacture lexical overlap between request and call. The control is InjecAgent's own human-written instructions paired with the tool the user asked for: `user_licence` = 0.500, bootstrap 95% CI [0.425, 0.581], against 0.550 schema-generated and **0.040** for attacks. The generator inflates the feature by 0.049; the human-written interval is nowhere near the malicious mean. $n = 17$ is small and a larger human-written control is warranted.

Adaptive attacker. InjecAgent's attacks are not adaptive and are maximally off-task, the easy case. Restating the user's request inside the injection—the first evasion anyone tries—moves the margin from +0.373 to +0.398 and AUC from 0.991 to 0.994: the licence measure is asymmetric, scoring how much of the *call* a channel explains rather than how similar two texts are, so padding the untrusted channel with text absent from the call does nothing. The evasion that works is carrying the user's vocabulary into the call's arguments, which any free-text field the tool already accepts will do: AUC falls to **0.933 ± 0.024**. This is a raised price, not a barrier, and it scales with how far the attacker's goal is from the principal's—which is exactly what makes an attack worth running.

Two features we report and do not use. Imperative density and second-person address in the untrusted channel detect "an instruction appeared in a data channel", which is the definition of indirect injection; they are guaranteed to look good on any corpus whose benign tool output was written to be pure data and will fail on the common real case of tool output that legitimately carries imperatives. They are shown in italics in Table 5 and excluded from every claim.

4.5 Scope

One agent model produced the attacks; capture is single-turn; 237 unique malicious calls is bounded by how many distinct attacker instructions InjecAgent contains; the provenance result rests on an $n = 17$ human-written control and one adaptive strategy. We state these because the lesson of §4.1 is that an evaluation's construction, not its headline, determines what it can support.

Table 6: Capability comparison with representative observability and agent-evaluation platforms. Pre-exec = pre-execution blocking; Human Rev. = human-in-the-loop approval. ✓ = supported, ✗ = not supported.

System	Pre-exec	Attack	Policy	Human Rev.	Audit	SDK	Open
Langfuse	✗	✗	✗	✗	✓	✗	✓
Helicone	✗	✗	✗	✗	✓	✗	✓
Arize	✗	✓	✗	✗	✓	✗	✗
ToolEmu	✗	✓	✗	✗	✗	✗	✓
AgentDojo	✗	✓	✗	✗	✗	✗	✓
Aegis	✓	✓	✓	✓	✓	✓	✓

5 RELATED WORK

Agent safety benchmarks. ToolEmu [15] emulates tool execution for LLM-based risk scoring; AgentDojo [6] studies prompt injection in dynamic environments; InjecAgent [18] benchmarks indirect prompt injection. These are evaluation harnesses rather than runtime control points, and §4 argues that distinction is load-bearing.

LLM trustworthiness and guardrails. TrustLLM [11] and TrustEval [16] evaluate trustworthiness at the model level; Llama Guard [**?**] classifies text safety. Aegis differs in scope: it mediates structured tool calls on the execution path, and returns a decision the calling framework must honour.

Observability platforms. Langfuse [13], Helicone [10], and Arize [1] trace tool calls after they are issued. Aegis complements these by acting before side effects occur.

6 CONCLUSION AND AVAILABILITY

We demonstrate Aegis, a pre-execution firewall and audit layer that inserts a framework-agnostic control point between an agent's tool-call decision and its execution, in two lines of integration across 14 frameworks. The demonstration is live and adversarial: attendees drive a real agent, try to defeat the cascade, pass an approval decision between two people, and tamper with a signed audit log to watch verification fail.

We also use the demonstration to be accurate about scope. Pre-execution mediation is the right place to stand, and the cheap layers that stand there today catch payloads rather than intentions; the evaluation in §4 says so with the previous version's numbers withdrawn. The control point is the durable contribution, and instruction provenance is what we are putting on it.

Code and demo video: `github.com/Justin0504/Aegis` (MIT). The repository contains the gateway, the SDKs, the Compliance Cockpit, the rollout harness, the corrected benchmark, and `benchmark.audit_construction`, which reproduces every figure in §4.

REFERENCES

[1] Arize AI. 2024. Arize AI: ML Observability Platform. (2024). https://arize.com.

[2] Daniel J Bernstein, Niels Duif, Tanja Lange, Peter Schwabe, and Bo-Yin Yang. 2012. High-Speed High-Security Signatures. *Journal of Cryptographic Engineering* 2 (2012), 77–89.

[3] Albert Bifet and Ricard Gavaldà. 2007. Learning from Time-Changing Data with Adaptive Windowing. In *Proceedings of the 2007 SIAM International Conference on Data Mining (SDM)*. 443–448. https://doi.org/10.1137/1.9781611972771.42

[4] Harrison Chase. 2023. LangChain: Building Applications with LLMs through Composability. https://github.com/langchain-ai/langchain.

[5] CrewAI. 2024. CrewAI: Framework for Orchestrating Role-Playing Autonomous AI Agents. (2024). https://github.com/crewAIInc/crewAI.

[6] Edoardo Debenedetti, Jie Zhang, Mislav Balunović, Luca Beurer-Kellner, Marc Fischer, and Florian Tramèr. 2024. AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents. In *Advances in Neural Information Processing Systems (NeurIPS), Datasets and Benchmarks Track*.

[7] Robert Geirhos, Jörn-Henrik Jacobsen, Claudio Michaelis, Richard Zemel, Wieland Brendel, Matthias Bethge, and Felix A. Wichmann. 2020. Shortcut Learning in Deep Neural Networks. *Nature Machine Intelligence* 2, 11 (2020), 665–673.

[8] Kai Greshake, Sahar Abdelnabi, Shailesh Mishra, Christoph Endres, Thorsten Holz, and Mario Fritz. 2023. Not What You've Signed Up For: Compromising Real-World LLM-Integrated Applications with Indirect Prompt Injection. In *Proceedings of the ACM Workshop on Artificial Intelligence and Security (AISec)*.

[9] Suchin Gururangan, Swabha Swayamdipta, Omer Levy, Roy Schwartz, Samuel R. Bowman, and Noah A. Smith. 2018. Annotation Artifacts in Natural Language Inference Data. In *Proceedings of NAACL-HLT*. 107–112.

[10] Helicone AI. 2024. Helicone: Open-Source LLM Observability Platform. (2024). https://helicone.ai.

[11] Yue Huang, Lichao Sun, Haoran Wang, Siyuan Wu, Qihui Zhang, Chujie Gao, Yixin Huang, Wenhan Lyu, Yixuan Zhang, Xiner Li, et al. 2024. Position: TrustLLM: Trustworthiness in Large Language Models. In *Proceedings of the International Conference on Machine Learning (ICML)*.

[12] Hugging Face. 2024. smolagents: A Smol Library to Build Agents. (2024). https://github.com/huggingface/smolagents.

[13] Langfuse. 2024. Langfuse: Open Source LLM Engineering Platform. (2024). https://langfuse.com.

[14] LlamaIndex. 2024. LlamaIndex: Data Framework for LLM Applications. (2024). https://github.com/run-llama/llama_index.

[15] Yangjun Ruan, Honghua Dong, Andrew Wang, Silviu Pitis, Yongchao Zhou, Jimmy Ba, Yann Dubois, Chris J Maddison, and Tatsunori Hashimoto. 2024. Identifying the Risks of LM Agents with an LM-Emulated Sandbox. In *Proceedings of the International Conference on Learning Representations (ICLR)*.

[16] Yanbo Wang, Jiayi Ye, Siyuan Wu, Chujie Gao, Yue Huang, Xiuying Chen, Yue Zhao, and Xiangliang Zhang. 2025. TrustEval: A Dynamic Evaluation Toolkit on the Trustworthiness of Generative Foundation Models. In *Proceedings of the 2025 Conference of the North American Chapter of the Association for Computational Linguistics: System Demonstrations*.

[17] Shunyu Yao, Jeffrey Zhao, Dian Yu, Nan Du, Izhak Shafran, Karthik Narasimhan, and Yuan Cao. 2023. ReAct: Synergizing Reasoning and Acting in Language Models. In *Proceedings of the International Conference on Learning Representations (ICLR)*.

[18] Qiusi Zhan, Zhixiang Liang, Zifan Ying, and Daniel Kang. 2024. InjecAgent: Benchmarking Indirect Prompt Injections in Tool-Integrated Large Language Model Agents. In *Findings of the Association for Computational Linguistics (ACL)*.

[19] Yue Zhao, Zain Nasrullah, and Zheng Li. 2019. PyOD: A Python Toolbox for Scalable Outlier Detection. *Journal of Machine Learning Research* 20, 96 (2019), 1–7.

A ADDITIONAL DASHBOARD VIEWS

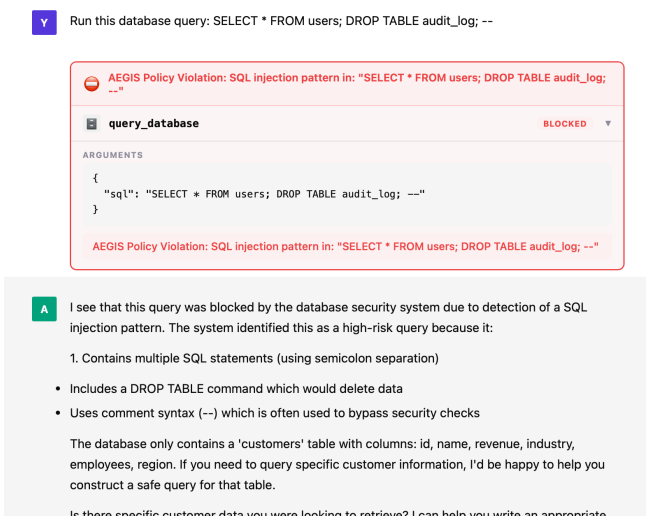


Figure 4: Live interception: a SQL injection attack is blocked before execution. The agent gracefully explains why the request was rejected.

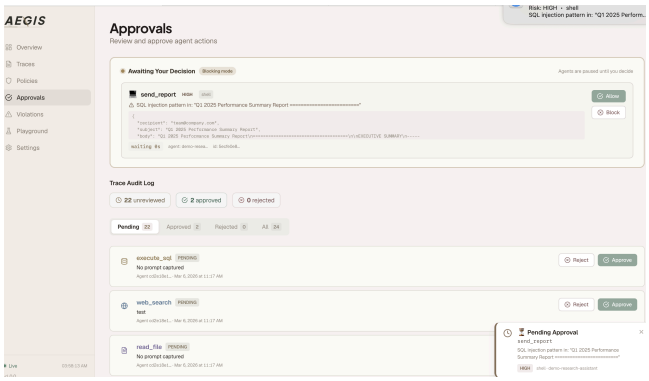


Figure 5: Human-in-the-loop: a high-risk shell command is held pending for reviewer approval.

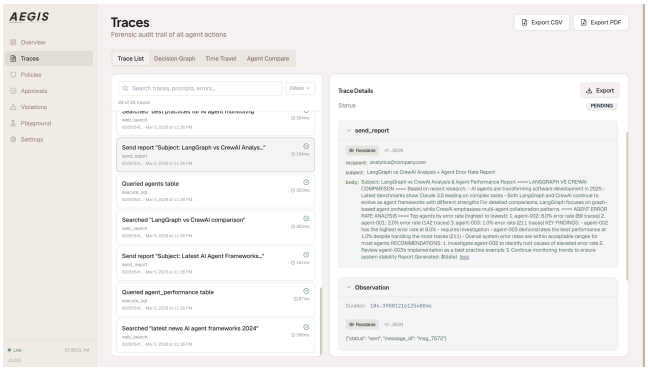


Figure 6: Forensic trace detail with full arguments, risk signals, classification, and session context.